CHAYIL SECUREX

INFORMATION SECURITY GRC MATURITY SELF-ASSESSMENT

ISO 27001:2022 Aligned | Healthcare & Financial Institutions | Ghana Regulatory Context

Version 1.0 | March 2026 | Cybersecurity Governance & GRC Advisory

WHAT IS THIS ASSESSMENT?
This tool allows your organisation to evaluate its current information security and governance posture against ISO 27001:2022 standards,
Ghana regulatory requirements (BoG ICT Directives / Ghana DPA), and cybersecurity best practice for your sector.
It takes 8–12 minutes to complete. Your results are calculated automatically.
The assessment is structured in 6 domains. For each question, select your current state from the dropdown.
Your maturity score and gap analysis will appear automatically on the Results tab.

HOW TO USE	
STEP 1	Select your sector tab below — '🏥 Healthcare Assessment' OR '🏦 Financial Assessment'
STEP 2	Enter your organisation name, role, and date at the top of the assessment
STEP 3	For each question, click the green response cell and select from the dropdown menu
STEP 4	Complete ALL questions — unanswered questions score 0 (Not Implemented)
STEP 5	View your instant results on the '📊 Results' tab — scores calculate automatically
STEP 6	Share your results with Chayil SecureX to discuss your remediation roadmap

RESPONSE OPTIONS & SCORING		
Not Implemented	Score: 0	No control or process exists
Planning Stage	Score: 1	Recognised as a need — not yet started
Partially Implemented	Score: 2	In place but incomplete or untested
Fully Implemented	Score: 3	Documented, implemented, and effective
Optimised	Score: 4	Tested, reviewed, and continuously improved

MATURITY LEVEL INTERPRETATION		
0%–30%	INITIAL	Minimal controls. Significant regulatory and cyber exposure. Immediate action required.
31%–50%	DEVELOPING	Basic controls exist but are incomplete. Material gaps remain. Structured remediation needed.
51%–65%	DEFINED	Controls are in place but inconsistently applied. Evidence gaps for audit. Moderate risk exposure.
66%–80%	MANAGED	Most controls implemented. Some gaps in documentation or testing. Good regulatory posture.
81%–100%	OPTIMISED	Comprehensive, tested, and documented controls. Strong compliance posture. ISO 27001-ready.

READY TO UNDERSTAND YOUR RISK EXPOSURE?
Select your sector tab at the bottom of this workbook and begin the assessment.
Questions? Contact Chayil SecureX — info@chayilsecurex.com | www.chayilsecurex.com

CHAYIL SECUREX | 🏥 HEALTHCARE ASSESSMENT | ISO 27001:2022 ALIGNED

GRC Maturity Assessment for Healthcare Providers — Clinics, Hospitals, and Medical Centres

Sector: Private Healthcare (Clinics / Hospitals) | Complete all dropdowns in the 'Your Response' column | Results update automatically

Organisation Name:	*e.g. ABC Medical Centre / XYZ Microfinance Ltd*
Completed By:	*Name and Job Title*
Date:	*2026-03-11*
Sector:	*Private Healthcare (Clinics / Hospitals)*

ID	#	Assessment Question	Why It Matters	Your Response (Select from dropdown)	Score (Auto)	Regulatory Reference
1. Governance & Policy						
HC-G1	1	Does your facility have a documented Information Security Policy approved by management?	*Undocumented security creates regulatory exposure and is the first ISO 27001 audit failure point.*	Planning Stage	1	*ISO 27001:2022 A.5.1 | Ghana DPA 2012*
HC-G2	2	Is there a designated Information Security Officer or Compliance Officer responsible for data protection?	*Without ownership, security controls are inconsistently applied. Ghana DPA requires a data controller.*	Planning Stage	1	*Ghana DPA 2012 s.17 | ISO 27001 A.5.2*
HC-G3	3	Has your organisation formally registered with the Data Protection Commission Ghana?	*Registration is a legal obligation under the Ghana Data Protection Act 2012.*	Planning Stage	1	*Ghana DPA 2012 s.17*
HC-G4	4	Are staff made aware of their data protection obligations at induction and annually?	*Staff are the primary cause of data breaches. Awareness is Clause 7.3 requirement.*	Not Implemented	0	*ISO 27001:2022 A.6.3 | Ghana DPA 2012*
HC-G5	5	Does your facility have a documented retention and disposal policy for patient records?	*Ghana DPA requires data is not kept longer than necessary. Medical records have defined retention periods.*	Not Implemented	0	*Ghana DPA 2012 | Ghana Health Service Records Policy*
Domain Score: 1. Governance & Policy				**3**	**15%**	
2. Patient Data & Access Control						
HC-A1	6	Is access to patient records restricted to authorised clinical and administrative staff only?	*Unrestricted access to patient data is a direct Ghana DPA violation and patient safety risk.*	Partially Implemented	2	*ISO 27001:2022 A.8.2 | Ghana DPA 2012*
HC-A2	7	Does your EMR or patient records system require a unique username and password for each user?	*Shared credentials make it impossible to audit who accessed patient data — a regulatory audit failure.*	Partially Implemented	2	*ISO 27001:2022 A.8.5 | Ghana DPA 2012*
HC-A3	8	Are access rights reviewed and updated when staff change roles or leave the organisation?	*Former staff retaining access is a critical security and DPA compliance gap.*	Partially Implemented	2	*ISO 27001:2022 A.5.18*
HC-A4	9	Is patient data encrypted when stored electronically or transmitted outside the facility?	*Unencrypted patient data is a breach waiting to happen. Ghana DPA requires appropriate technical safeguards.*	Planning Stage	1	*ISO 27001:2022 A.8.24 | Ghana DPA 2012*
HC-A5	10	Do you conduct quarterly reviews of who has access to patient data systems?	*Access creep is the most common insider threat vector. Regular review is an ISO 27001 requirement.*	Not Implemented	0	*ISO 27001:2022 A.5.18*
Domain Score: 2. Patient Data & Access Control				**7**	**35%**	
3. Clinical System Security						
HC-S1	11	Are all workstations and devices used for patient data protected with up-to-date anti-malware software?	*Healthcare systems are primary ransomware targets. Unprotected endpoints can encrypt all patient records.*	Partially Implemented	2	*ISO 27001:2022 A.8.7*
HC-S2	12	Are operating system and software patches applied regularly (at least monthly)?	*Unpatched systems are the most exploited attack vector. Monthly patching is security baseline.*	Not Implemented	0	*ISO 27001:2022 A.8.8*
HC-S3	13	Are patient data systems backed up daily, with backups stored securely off-site or in the cloud?	*Without verified backups, a ransomware attack means permanent loss of all patient records.*	Not Implemented	0	*ISO 27001:2022 A.8.13*
HC-S4	14	Are backup restoration procedures tested at least quarterly to confirm recovery is possible?	*Untested backups frequently fail when needed. Restoration testing is an ISO 27001 audit requirement.*	Not Implemented	0	*ISO 27001:2022 A.8.13*
HC-S5	15	Is your Wi-Fi network segmented so that patient data systems are separate from guest or public Wi-Fi?	*Shared networks allow attackers to move from a compromised guest device to clinical systems.*	Not Implemented	0	*ISO 27001:2022 A.8.22*
Domain Score: 3. Clinical System Security				**2**	**10%**	
4. Incident Response & Business Continuity						
HC-I1	16	Does your facility have a documented procedure for responding to a data breach or cyber incident?	*Without a documented plan, breach response is chaotic and slow — increasing patient harm and regulatory exposure.*	Not Implemented	0	*ISO 27001:2022 A.5.26 | Ghana DPA s.35*
HC-I2	17	Do you know your legal obligation to notify the Data Protection Commission in the event of a patient data breach?	*Ghana DPA requires breach notification to affected individuals and the DPC. Ignorance is not a defence.*	Not Implemented	0	*Ghana DPA 2012 s.35*
HC-I3	18	Has your facility conducted a cyber incident tabletop exercise in the past 12 months?	*Tested plans work. Untested plans fail at the moment of crisis.*	Planning Stage	1	*ISO 27001:2022 A.5.26 | ISO 22301*
HC-I4	19	Can your facility continue clinical operations manually if your IT systems are unavailable for 24 hours?	*Clinical continuity is a patient safety requirement. IT failures without fallback procedures endanger patients.*	Partially Implemented	2	*ISO 22301 | Ghana Health Service BCP Requirements*
HC-I5	20	Is there a documented process for disposing of old computers, hard drives, and USB devices containing patient data?	*Improperly disposed devices are a common source of patient data breaches and DPA violations.*	Planning Stage	1	*ISO 27001:2022 A.8.10 | Ghana DPA 2012*
Domain Score: 4. Incident Response & Business Continuity				**4**	**20%**	
5. Third-Party & Vendor Risk						
HC-V1	21	Do all technology vendors with access to patient data sign a data processing agreement?	*Ghana DPA requires contractual obligations on all data processors. Missing DPAs create direct legal liability.*	Planning Stage	1	*Ghana DPA 2012 s.22 | ISO 27001:2022 A.5.19*
HC-V2	22	Do you assess the security practices of your EMR vendor, cloud provider, or IT support company?	*Vendor breaches become your breach. Your DPA obligations extend to your processors.*	Planning Stage	1	*ISO 27001:2022 A.5.19*
HC-V3	23	Are remote access sessions by IT vendors monitored and logged?	*Unmonitored remote access is a high-risk insider threat and compliance gap.*	Planning Stage	1	*ISO 27001:2022 A.5.20*
Domain Score: 5. Third-Party & Vendor Risk				**3**	**25%**	
6. Physical Security						
HC-P1	24	Is access to server rooms, medical record stores, and IT equipment restricted to authorised staff?	*Physical access to IT equipment is equivalent to digital access. Uncontrolled physical access enables data theft.*	Partially Implemented	2	*ISO 27001:2022 A.7.4*
HC-P2	25	Are visitor access logs maintained for sensitive areas of the facility?	*Visitor logs are required evidence for ISO 27001 physical security audits.*	Partially Implemented	2	*ISO 27001:2022 A.7.4*
HC-P3	26	Are workstations locked automatically after a period of inactivity?	*Unattended unlocked workstations in clinical areas allow unauthorised patient data access.*	Planning Stage	1	*ISO 27001:2022 A.8.1*
HC-P4	27	Is CCTV operational in data centre, server room, or areas where patient records are stored?	*CCTV is a deterrent and evidence requirement for physical security compliance.*	Planning Stage	1	*ISO 27001:2022 A.7.4*
Domain Score: 6. Physical Security				**6**	**38%**	

CHAYIL SECUREX | 🏦 FINANCIAL ASSESSMENT | ISO 27001:2022 ALIGNED

GRC Maturity Assessment for Financial Institutions — MFIs, S&Ls, Fintechs, Rural Banks

Sector: Financial Institution (MFI / S&L / Fintech / Rural Bank) | Complete all dropdowns in the 'Your Response' column | Results update automatically

Organisation Name:	*e.g. ABC Medical Centre / XYZ Microfinance Ltd*
Completed By:	*Name and Job Title*
Date:	*2026-03-11*
Sector:	*Financial Institution (MFI / S&L / Fintech / Rural Bank)*

ID	#	Assessment Question	Why It Matters	Your Response (Select from dropdown)	Score (Auto)	Regulatory Reference
1. Governance & Regulatory Compliance						
FI-G1	1	Does your institution have a documented Information Security Policy approved by the Board?	*BoG ICT Directives require board-approved ICT governance policies. Absence is a primary examination finding.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.5.1*
FI-G2	2	Is there a designated Compliance Officer or Risk Officer responsible for ICT security governance?	*BoG expects named accountability for ICT risk. Absence signals governance failure to examiners.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.5.2*
FI-G3	3	Has your institution registered with the Data Protection Commission Ghana?	*Ghana DPA registration is a legal obligation. Financial institutions hold significant personal data.*	Not Implemented	0	*Ghana DPA 2012 s.17*
FI-G4	4	Do you conduct an annual ICT risk assessment aligned to BoG ICT governance requirements?	*BoG examiners specifically assess whether institutions conduct documented risk assessments.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 Clause 6.1*
FI-G5	5	Does your institution have a documented Segregation of Duties policy for financial and IT operations?	*Segregation of duties is a fundamental banking control. Absence creates fraud risk and regulatory exposure.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.5.3*
FI-G6	6	Are all staff trained on information security, fraud prevention, and AML obligations annually?	*Human error and social engineering cause the majority of financial fraud incidents.*	Not Implemented	0	*AML Act 2008 (Act 749) | ISO 27001:2022 A.6.3*
Domain Score: 1. Governance & Regulatory Compliance				**0**	**0%**	
2. Customer Data & AML/KYC Compliance						
FI-D1	7	Is customer financial data encrypted at rest and in transit across all systems?	*Ghana DPA requires appropriate technical safeguards for personal financial data. Unencrypted data is a legal liability.*	Not Implemented	0	*Ghana DPA 2012 | ISO 27001:2022 A.8.24*
FI-D2	8	Are KYC records complete, accurate, and accessible for all active customers?	*Incomplete KYC records are a primary AML Act violation and FIC examination finding.*	Not Implemented	0	*AML Act 2008 (Act 749) | FIC Requirements*
FI-D3	9	Does your institution have a documented process for detecting and reporting suspicious transactions to the FIC?	*Suspicious Transaction Reporting (STR) is a mandatory obligation under the AML Act. Failure triggers FIC sanctions.*	Not Implemented	0	*AML Act 2008 (Act 749) s.35*
FI-D4	10	Are customer data access rights reviewed when staff change roles or leave the institution?	*Former employees retaining access to customer financial data creates fraud risk and DPA violations.*	Not Implemented	0	*ISO 27001:2022 A.5.18 | Ghana DPA 2012*
FI-D5	11	Is customer financial data retained for the minimum periods required by BoG (7 years for transaction records)?	*BoG requires minimum 7-year retention for transaction records. Shorter retention creates regulatory exposure.*	Not Implemented	0	*BoG ICT Directive | Ghana DPA 2012*
Domain Score: 2. Customer Data & AML/KYC Compliance				**0**	**0%**	
3. Core Banking & Transaction Security						
FI-T1	12	Does your institution have real-time or near-real-time transaction monitoring for fraud detection?	*Cyber-enabled fraud is the primary financial institution cyber threat. Manual monitoring is insufficient.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.8.16*
FI-T2	13	Are high-value transactions and system configuration changes subject to dual authorisation?	*Single-approver controls on high-value transactions are a fundamental fraud risk and governance gap.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.5.3*
FI-T3	14	Are transaction and system audit logs retained immutably for minimum 7 years?	*BoG requires transaction audit logs for examination. Mutable or deleted logs constitute a regulatory violation.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.8.15*
FI-T4	15	Is multi-factor authentication enforced for all staff accessing core banking or customer account systems?	*Credential theft is the most common account takeover vector. MFA is the single most effective preventive control.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.8.5*
FI-T5	16	Are interbank payment messages (GhIPSS / ACH) transmitted with integrity verification and encryption?	*Unprotected interbank messages can be intercepted and modified — enabling fraudulent transfers.*	Not Implemented	0	*GhIPSS Security Requirements | ISO 27001:2022 A.8.24*
Domain Score: 3. Core Banking & Transaction Security				**0**	**0%**	
4. Cyber Threat & Incident Response						
FI-I1	17	Does your institution have a documented Cyber Incident Response Plan?	*BoG requires institutions to report cyber incidents within 24 hours. An untested IRP causes regulatory violations.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.5.26*
FI-I2	18	Are all workstations and servers protected with up-to-date endpoint detection and response (EDR) software?	*Financial institutions are primary ransomware targets. Unprotected endpoints can paralyse all operations.*	Not Implemented	0	*ISO 27001:2022 A.8.7 | BoG ICT Directive*
FI-I3	19	Are operating systems and applications patched on a defined schedule (at minimum monthly)?	*Unpatched systems are exploited within hours of vulnerability disclosure. Monthly patching is the security baseline.*	Not Implemented	0	*ISO 27001:2022 A.8.8*
FI-I4	20	Has your institution conducted a cyber incident tabletop exercise in the past 12 months?	*Tested plans work. BoG expects evidence of BCP and incident response testing.*	Not Implemented	0	*BoG ICT Directive | ISO 27001:2022 A.5.26*
FI-I5	21	Does your institution have a documented procedure for notifying BoG within 24 hours of a cyber incident?	*BoG reporting obligation is regulatory requirement. Missing notification procedure causes examination failure.*	Not Implemented	0	*BoG ICT Directive Circular*

CHAYIL SECUREX | GRC MATURITY RESULTS DASHBOARD

Your maturity scores are calculated automatically from your assessment responses. All numbers update as you complete the tabs.

Complete the Healthcare or Financial assessment tab first, then return here to view your results.

🏥 HEALTHCARE PROVIDER — GRC MATURITY RESULTS

Domain	Your Score	Max Score	Maturity %	Maturity Level	RAG	Priority
1. Governance & Policy	3	20	15%	INITIAL	🔴 HIGH RISK	Immediate Action
2. Patient Data & Access Control	7	20	35%	DEVELOPING	🔴 HIGH RISK	Immediate Action
3. Clinical System Security	2	20	10%	INITIAL	🔴 HIGH RISK	Immediate Action
4. Incident Response & Business Continuity	4	20	20%	INITIAL	🔴 HIGH RISK	Immediate Action
5. Third-Party & Vendor Risk	3	12	25%	INITIAL	🔴 HIGH RISK	Immediate Action
6. Physical Security	6	16	38%	DEVELOPING	🔴 HIGH RISK	Immediate Action
OVERALL HEALTHCARE SCORE	**25**	**108**	**23%**	**INITIAL — Immediate Action Required**		

🏦 FINANCIAL INSTITUTION — GRC MATURITY RESULTS

Domain	Your Score	Max Score	Maturity %	Maturity Level	RAG	Priority
1. Governance & Regulatory Compliance	0	24	0%	INITIAL	🔴 HIGH RISK	Immediate Action
2. Customer Data & AML/KYC Compliance	0	20	0%	INITIAL	🔴 HIGH RISK	Immediate Action
3. Core Banking & Transaction Security	0	20	0%	INITIAL	🔴 HIGH RISK	Immediate Action
4. Cyber Threat & Incident Response	0	20	0%	INITIAL	🔴 HIGH RISK	Immediate Action
5. Third-Party & Fintech Risk	0	16	0%	INITIAL	🔴 HIGH RISK	Immediate Action
6. Business Continuity & Physical Security	0	20	0%	INITIAL	🔴 HIGH RISK	Immediate Action
OVERALL FINANCIAL SCORE	**0**	**120**	**0%**	**INITIAL — Immediate Action Required**		

WHAT YOUR SCORE MEANS FOR YOUR ORGANISATION

A score below 65% indicates material gaps in your information security controls and regulatory compliance posture.

These gaps create direct exposure to cyber attacks, regulatory sanctions, and reputational risk.

WHAT CHAYIL SECUREX CAN DO FOR YOU

We translate your assessment results into a prioritised GRC remediation roadmap — structured, actionable, and audit-ready.

Our engagements deliver: ISO 27001-aligned risk register | Control implementation support | Policy suite | BoG/DPA compliance advisory | Board reporting

NEXT STEP: Share this completed assessment with Chayil SecureX for a FREE 30-minute results review

info@chayilsecurex.com | www.chayilsecurex.com | Accra, Ghana